HARMONY SPA

Plantilla 2 · Matriz de endpoints y taller

Documento de trabajo académico · Versión 1.0 · Elaborado para el taller de diseño de API REST

Nota: los requisitos marcados como “por confirmar” son decisiones de negocio que Harmony Spa debe validar antes de implementar.

1. Instrucciones del taller

Propósito: convertir requisitos funcionales aprobados de Harmony Spa en endpoints claros, autorizados, comprobables y documentados. La matriz es una propuesta inicial; el equipo debe validarla con el negocio.

Fase	Actividad	Entregable
1. Identificar	Listar módulos, recursos, roles y RF.	Mapa de módulos y recursos
2. Diseñar	Elegir método HTTP, ruta, entradas, permisos y respuesta.	Matriz de endpoints
3. Revisar seguridad	Verificar autenticación, autorización y propiedad del recurso.	Matriz de acceso por rol
4. Probar	Definir casos positivos y negativos; ejecutar con Postman/Insomnia.	Evidencias de pruebas
5. Ajustar	Corregir rutas, contratos y criterios según resultados.	API documentada y validada

2. Convenciones de diseño

- Prefijo de versión propuesto: /api/v1.
- Usar sustantivos en plural para recursos: /clientes, /citas, /productos.
- GET consulta; POST crea o ejecuta una operación; PUT reemplaza una representación; PATCH modifica parcialmente; DELETE elimina o solicita la eliminación del recurso.
- Usar :id como marcador de ruta en esta plantilla; en la URL real se reemplaza por el identificador, por ejemplo /citas/123.
- Los nombres de rutas son propuestas, no un estándar obligatorio. Mantener consistencia en todo el proyecto.
- El rol no reemplaza la autorización por recurso: un cliente solo puede leer o modificar sus propios datos, salvo operaciones públicas.
- Preferir desactivación lógica cuando se requiera conservar historial financiero, citas, sesiones o auditoría.
- Los pagos deben ser idempotentes donde aplique y no deben duplicarse por reintentos.
- Usar HTTPS en producción; no enviar contraseñas ni tokens en URLs.

3. Referencia rápida de métodos y códigos HTTP

Método	Uso típico	Ejemplo Harmony Spa	Códigos comunes
GET	Consultar sin modificar el estado del recurso	GET /api/v1/citas/mias	200, 401, 403, 404
POST	Crear un recurso o ejecutar una acción	POST /api/v1/citas	201, 400/422, 401, 403, 409
PUT	Reemplazar una representación completa	PUT /api/v1/clientes/me	200/204, 400/422, 401, 403
PATCH	Actualizar parcialmente	PATCH /api/v1/clientes/me	200/204, 400/422, 401, 403
DELETE	Eliminar o solicitar eliminación de un recurso	DELETE /api/v1/empleados/:id	204, 401, 403, 404, 409

Nota: el uso exacto de PUT y PATCH debe quedar definido en el contrato de la API. Los códigos HTTP son ejemplos y deben ajustarse a las respuestas reales.

4. Matriz inicial de endpoints propuesta

ID	Módulo	Método	Endpoint	Rol/acceso (propuesta)	Propósito	Códigos orientativos
E-001	Autenticación	POST	/api/v1/auth/register	Público	Crear cuenta cliente	201; 400/422; 409
E-002	Autenticación	POST	/api/v1/auth/login	Público	Iniciar sesión	200; 400/401; 429
E-003	Autenticación	POST	/api/v1/auth/logout	Usuario autenticado	Cerrar sesión / invalidar token según estrategia	204; 401
E-004	Autenticación	POST	/api/v1/auth/refresh	Según estrategia de tokens	Renovar token	200; 401
E-005	Perfil	GET	/api/v1/clientes/me	Cliente	Consultar perfil propio	200; 401; 404
E-006	Perfil	PATCH	/api/v1/clientes/me	Cliente	Actualizar campos permitidos del perfil propio	200; 400/422; 401
E-007	Clientes	GET	/api/v1/clientes	Super admin; admin si se autoriza	Listar clientes con filtros/paginación	200; 401; 403
E-008	Clientes	POST	/api/v1/clientes	Super admin	Registrar cliente manualmente	201; 400/422; 409
E-009	Clientes	GET	/api/v1/clientes/:id	Roles administrativos autorizados	Consultar ficha de cliente	200; 401; 403; 404
E-010	Clientes	PATCH	/api/v1/clientes/:id	Super admin; admin según política	Actualizar cliente administrativamente	200; 400/422; 403; 404
E-011	Empleados	GET	/api/v1/empleados	Super admin	Listar empleados	200; 401; 403
E-012	Empleados	POST	/api/v1/empleados	Super admin	Crear empleado admin o esteticista	201; 400/422; 403; 409
E-013	Empleados	GET	/api/v1/empleados/:id	Super admin	Consultar empleado	200; 403; 404
E-014	Empleados	PATCH	/api/v1/empleados/:id	Super admin	Modificar datos o estado del empleado	200; 400/422; 403; 404
E-015	Empleados	DELETE	/api/v1/empleados/:id	Super admin	Desactivar empleado, sujeto a historial	204; 403; 404; 409
E-016	Procedimientos	GET	/api/v1/procedimientos	Público/usuarios autorizados	Listar catálogo activo	200
E-017	Procedimientos	GET	/api/v1/procedimientos/:id	Público/usuarios autorizados	Consultar detalle	200; 404
E-018	Procedimientos	POST	/api/v1/procedimientos	Super admin o rol por confirmar	Crear procedimiento	201; 400/422; 403
E-019	Procedimientos	PATCH	/api/v1/procedimientos/:id	Super admin o rol por confirmar	Modificar precio, duración, sesiones o estado	200; 400/422; 403; 404
E-020	Agenda	GET	/api/v1/disponibilidad?procedimientoId=:id&fecha=:fecha	Público/cliente	Consultar espacios disponibles	200; 400/422
E-021	Citas	POST	/api/v1/citas	Cliente; admin según política	Reservar cita	201; 400/422; 401; 403; 409
E-022	Citas	GET	/api/v1/citas/mias	Cliente	Consultar citas propias	200; 401
E-023	Citas	GET	/api/v1/citas	Super admin; admin; esteticista con filtro propio	Consultar agenda según rol	200; 401; 403
E-024	Citas	GET	/api/v1/citas/:id	Propietario o rol autorizado	Consultar detalle de cita	200; 401; 403; 404
E-025	Citas	POST	/api/v1/citas/:id/cancelacion	Cliente propietario; admin bajo política	Solicitar cancelación y calcular consecuencia	200; 400/422; 401; 403; 409
E-026	Citas	PATCH	/api/v1/citas/:id	Super admin/admin autorizado	Reprogramar o cambiar estado permitido	200; 400/422; 403; 409
E-027	Tratamientos	POST	/api/v1/tratamientos	Rol autorizado	Crear plan de tratamiento de varias sesiones	201; 400/422; 403
E-028	Tratamientos	GET	/api/v1/tratamientos/mios	Cliente	Consultar planes propios	200; 401
E-029	Tratamientos	GET	/api/v1/tratamientos/:id	Cliente propietario o personal autorizado	Consultar progreso del plan	200; 401; 403; 404
E-030	Sesiones	GET	/api/v1/tratamientos/:id/sesiones	Cliente propietario o personal autorizado	Listar sesiones del plan	200; 403; 404
E-031	Sesiones	PATCH	/api/v1/sesiones/:id	Esteticista asignada; admin/super admin según política	Registrar estado y notas de sesión	200; 400/422; 403; 409
E-032	Calificaciones	POST	/api/v1/sesiones/:id/calificacion	Cliente propietario	Calificar una sesión completada	201; 400/422; 401; 403; 409
E-033	Calificaciones	POST	/api/v1/tratamientos/:id/calificacion	Cliente propietario	Calificar el tratamiento finalizado	201; 400/422; 401; 403; 409
E-034	Productos	GET	/api/v1/productos	Super admin/admin; catálogo público si corresponde	Consultar productos según categoría/permisos	200; 401; 403
E-035	Productos	POST	/api/v1/productos	Super admin	Crear producto comercial o de uso interno	201; 400/422; 403
E-036	Productos	PATCH	/api/v1/productos/:id	Super admin	Actualizar producto, categoría o estado	200; 400/422; 403; 404

E-037	Inventario	GET	/api/v1/inventario/movimientos	Super admin; admin con permisos definidos	Consultar movimientos de inventario	200; 401; 403
E-038	Ventas	POST	/api/v1/ventas	Super admin/admin autorizado	Registrar venta de productos comerciales	201; 400/422; 403; 409
E-039	Ventas	GET	/api/v1/ventas/:id	Super admin/admin autorizado; cliente para su compra si se habilita	Consultar venta	200; 401; 403; 404
E-040	Pagos	POST	/api/v1/pagos	Cliente o caja según flujo	Registrar/iniciar pago de tratamiento o venta	201/202; 400/422; 409
E-041	Pagos	GET	/api/v1/pagos/:id	Propietario o rol autorizado	Consultar estado del pago	200; 401; 403; 404
E-042	Penalidades	GET	/api/v1/penalidades/mias	Cliente	Consultar penalidades propias	200; 401
E-043	Reportes	GET	/api/v1/reportes/ventas?desde=:fecha&hasta=:fecha	Super admin/admin autorizado	Consultar reporte de ventas	200; 400/422; 403
E-044	Reportes	GET	/api/v1/reportes/citas?desde=:fecha&hasta=:fecha	Super admin/admin autorizado	Consultar reporte de citas	200; 400/422; 403

5. Matriz de diseño detallado de un endpoint

Campo	Ejemplo: crear una cita
ID / requisito relacionado	E-021 / RF-CIT-01
Método y ruta	POST /api/v1/citas
Actor	Cliente autenticado
Autorización	Cliente puede crear cita para sí mismo; no confiar en clienteId enviado por frontend.
Headers	Authorization: Bearer <token>; Content-Type: application/json
Query / path params	No requiere parámetros de ruta; filtros de disponibilidad se consultan en otro endpoint.
Body de ejemplo	{"procedimientoId": 12, "fechaHora": "2026-11-10T14:00:00-05:00", "preferenciaEsteticistaId": 8}
Validaciones	Procedimiento activo; fecha futura; horario disponible; esteticista elegible; reglas de duración y disponibilidad.
Regla de concurrencia	La reserva debe evitar que dos clientes ocupen el mismo espacio simultáneamente.
Respuesta exitosa	201 Created con id, estado, fechaHora, procedimiento y resumen del precio.
Errores esperados	401 sin sesión; 403 si no autorizado; 404 procedimiento inexistente; 409 horario ocupado; 422 datos inválidos.
Pruebas mínimas	Reserva válida; fecha pasada; procedimiento inactivo; horario ocupado; token ausente; intento de reservar para otro cliente.

6. Reglas críticas que deben definirse antes de programar

Regla	Pregunta que debe responder el equipo / negocio
Cancelación	¿“Un día antes” significa 24 horas exactas o hasta una hora límite del día anterior? Definir zona horaria del spa.
Penalidad del 10%	¿Se calcula sobre la cita individual, el valor total del tratamiento o algún otro importe? ¿Cómo se recauda?
Tratamiento de varias sesiones	El tratamiento se paga completo desde la primera sesión. ¿Qué política aplica a reembolsos, interrupciones o cancelación por el spa?
Sesión no cancelada a tiempo	El caso indica que la sesión se da por brindada. ¿Se marca automáticamente como consumida o requiere confirmación? ¿Cómo se evita marcarla antes de la hora?
Inventarios	¿Productos de venta y productos para procedimientos comparten inventario o son categorías/almacenes separados?
Permisos admin	Confirmar exactamente qué operaciones puede realizar admin sobre clientes, procedimientos, ventas, citas y reportes.
Esteticista	Definir si puede ver notas del cliente, modificar citas, registrar consumos, cerrar sesiones y ver historial.
Calificaciones	Definir escala, comentarios, edición, moderación y si solo se puede calificar una sesión completada.

Borrado y trazabilidad	Definir qué entidades se desactivan en lugar de borrarse y qué operaciones deben auditarse.
Pagos	Definir proveedor, estados de pago, conciliación, idempotencia, devoluciones y comprobantes.

7. Casos de prueba para Postman/Insomnia

Caso	Solicitud / condición	Resultado esperado	Resultado real / evidencia
TC-01	GET /api/v1/procedimientos sin iniciar sesión	200 y catálogo público activo, si se define público	[Completar]
TC-02	POST /api/v1/citas con cliente autenticado y horario libre	201 y cita creada	[Completar]
TC-03	POST /api/v1/citas con horario ocupado	409 o error de conflicto documentado	[Completar]
TC-04	POST /api/v1/empleados como admin	403 Forbidden	[Completar]
TC-05	PATCH /api/v1/clientes/me como cliente	200/204; actualiza solo campos permitidos del propio perfil	[Completar]
TC-06	GET /api/v1/clientes/:id intentando consultar a otro cliente	403 o 404 según política para evitar revelar existencia	[Completar]
TC-07	Cancelar cita dentro del plazo	Cancelación sin penalidad, si así lo define la regla	[Completar]
TC-08	Cancelar cita fuera del plazo para cita individual	Aplicación de penalidad del 10% según base aprobada	[Completar]
TC-09	No asistir a sesión de tratamiento multisesión sin cancelar a tiempo	Sesión marcada como consumida según política validada; no duplicar el cobro del plan	[Completar]
TC-10	POST de calificación para sesión no realizada	Rechazo según regla de negocio	[Completar]

8. Plantilla vacía para que cada equipo complete

ID	Módulo	Método	Ruta	Rol	Acción	Parámetros	Body	Reglas	Respuesta	Prueba	Estado
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]
[E-___]	[Módulo]	[GET/POST/PUT/PATCH/DELETE]	[/api/v1/...]	[Rol]	[Acción]	[Parámetros]	[Body]	[Reglas/validaciones]	[Respuesta/códigos]	[Prueba]	[Estado]

9. Criterios de entrega

- Todos los requisitos funcionales que el equipo priorice tienen endpoints o se justifica por qué no necesitan uno.
- No hay dos rutas que hagan lo mismo sin razón documentada.
- Los métodos HTTP representan correctamente la operación.
- Se especifican roles y autorización a nivel de recurso, no solo de pantalla.
- Se documentan parámetros, cuerpo, respuestas y errores.
- Se prueban al menos cinco casos positivos y cinco negativos o de seguridad.
- Las decisiones pendientes sobre penalidades, sesiones y pagos quedan registradas y no se inventan en código.
- Se entrega matriz, colección de pruebas y breve sustentación del diseño.

10. Espacio de aprobación del contrato de API

Rol	Nombre	Fecha	Observaciones
Representante Harmony Spa	[Completar]	[Completar]	[Completar]
Equipo de desarrollo	[Completar]	[Completar]	[Completar]
Instructor	[Completar]	[Completar]	[Completar]